AIC · AI+开源

SpringGuard

基于 Open Code Review 的 Spring 智能审查增强

确定性规则 × 可选 AI × 可复现评测

问题：Spring 审查的痛点

- 事务自调用失效、缺 `@Valid`、MyBatis `${}` 注入
- 纯 LLM：不稳定、难复核、成本高
- 纯静态工具：缺语义叙述与开源 Agent 生态

目标

- 无模型也能稳定检出核心 Spring 缺陷
- 可挂接上游 OCR + 本地 Ollama
- 金标准评测，拒绝「模型自评」
- 开源边界清晰：自研 vs 上游可核对

开源选型

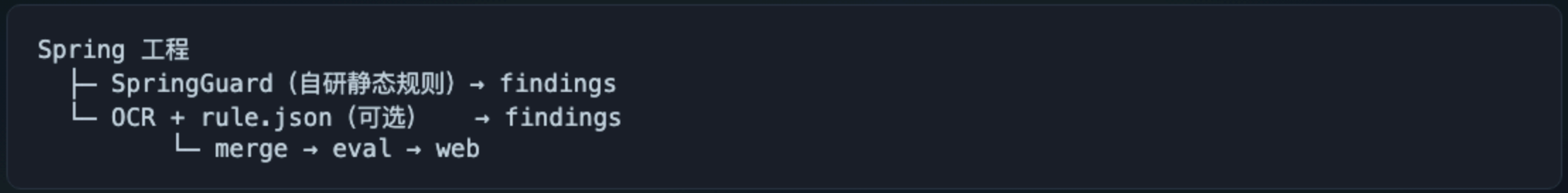
上游

alibaba/open-code-review
确定性工程 × Agent
自定义规则包 · JSON 输出

为什么选它

可扩展、可本地模型、
二次开发切口清晰、
避免从零造审查引擎

方案架构


Spring 工程
├─ SpringGuard（自研静态规则）→ findings
└─ OCR + rule.json（可选） → findings
└─ merge → eval → web

创新点（相对薄封装）

- **SpringGuard**：Controller / Service / Mapper 确定性规则
- **规则包**：`.opencodereview/rule.json` 领域提示
- **混合流水线**：编排 + 归一化合并
- **金标准评测**：6 类缺陷 Recall

评测结果（可脚本复现）

模式	TP	Recall
spring_guard	6/6	1.00
ocr_only（本轮长时未完成）	0	0.00
hybrid（本轮≈Guard）	6/6	1.00

演示以 Guard 为主；OCR 连通性已验证（`ocr llm test`）。

自研 vs 上游

模块	归属
Open Code Review CLI	上游 Apache-2.0
SpringGuard 引擎	自研
Spring 规则包 / 评测 / 样例 / 演示	自研

一键演示

```
./scripts/demo.sh
# → http://127.0.0.1:5193/
# Recall = 1.0 (spring_guard)
```

口播稿：docs/DEMO_SCRIPT.md

总结

把开源 AI 审查底座，变成可复现的 Spring 工程安全网。

- 后续：负例集 / Precision、CI 接入、更多 Spring 规则